

From Breach to Boardroom

Applying attack frameworks, compliance response, and security culture to a real-world-style incident

This afternoon, you step into the role of an internal incident response team called in after a cybersecurity incident. Using the frameworks and concepts from this morning's lectures — Compliance, Audits & Security Awareness (Lesson 1) and Understanding Attack Methodologies & Frameworks (Lesson 2) — you will reconstruct what happened, determine what the organization is legally obligated to do next, and recommend how to prevent it from happening again.

What You'll Practice

This workshop asks you to apply concepts from both of today's lessons in one integrated scenario:

- Describe the common stages of a cyberattack and map a real timeline to the Cyber Kill Chain.
- Apply the MITRE ATT&CK framework to name specific tactics, techniques, and procedures (TTPs).
- Classify the incident using the common attack types covered in Lesson 2 — and justify your reasoning.
- Identify which compliance frameworks (HIPAA, GDPR, PCI-DSS, SOX) apply — and just as importantly, which do not.
- Design an audit and remediation plan using the four-phase audit lifecycle from Lesson 1.
- Propose a security awareness training and culture initiative that addresses the root cause.

Deliverables

1. A completed Incident Response & Compliance Worksheet (Parts 1–7) — one per team.
2. A (“board readout”) summarizing your findings and recommendations, using your Part 7 outline.

Team Roles

You will wear many hats as you cover several roles.

Role	Leads On	Responsibilities
Incident Analyst	Parts 1–2	Owns the Kill Chain mapping and the MITRE ATT&CK TTP table. Keeps the team grounded in what the evidence actually says.
Compliance Lead	Parts 3–4	Owns the attack type classification and the regulatory impact analysis. Double-checks which frameworks do and do not apply.
Audit & Remediation Lead	Part 5	Owns the audit and remediation plan across all four lifecycle phases (Planning, Execution, Reporting, Follow-Up).

Culture & Training Lead	Parts 6–7	Owens the security awareness and culture proposal, and pulls the team's work together into the executive summary and presentation.
------------------------------------	-----------	--

Ground Rules

- Work from the timeline. Every claim you make in this worksheet should trace back to something stated in your scenario — don't invent facts that aren't there.
- Justify your classifications. “It's phishing” or “GDPR applies” is not a complete answer on its own — explain why, citing specific evidence.
- It's okay to say a framework doesn't apply. Part of this exercise is learning to correctly rule things out, not just list every framework you've heard of.
- Use the framework vocabulary. Where possible, name the exact Kill Chain stage, ATT&CK tactic/technique, or audit phase — not just a general description.

Your Scenario Track

Organization	Primary Regulatory Context	What Makes It Interesting
UrbanTrail Outfitters (retail / e-commerce)	PCI-DSS	A leftover contractor account becomes the way in.

Turn to your assigned track's scenario to begin.

UrbanTrail Outfitters

A privately held outdoor apparel retailer — 40 physical stores plus an online storefront, all sharing one point-of-sale (POS) network.

Background

- UrbanTrail Outfitters is a privately held retail chain with 40 stores and an online storefront. All in-store point-of-sale (POS) terminals connect to a shared corporate network that also carries employee email and guest Wi-Fi — the POS terminals were never placed on a separate, segmented network.
- Each fall, UrbanTrail hires short-term IT contractors to help configure new POS terminals ahead of the holiday season. Contractor accounts are created quickly to meet the deadline, but there has historically been no formal process for disabling them once a contract ends.
- One such contractor, hired for eight weeks the previous year, was given elevated access to the POS terminal configuration system. His contract ended three months before this incident began.

Incident Timeline

When	What Happened
Week 1	While testing a personal automation script, the former contractor accidentally commits a configuration file to a public GitHub repository. The file includes his old UrbanTrail login credentials in plain text. His account was never disabled after his contract ended.
Week 2	An unknown party discovers the exposed credentials — automated tools routinely scan public code repositories for exactly this kind of accidental exposure. The account still has valid, elevated access to UrbanTrail's POS configuration system.
Week 2, late	Using the still-active account, the attacker logs into the POS configuration system remotely and pushes a “firmware update” to terminals at 40 store locations. The update installs a small program that reads card data directly from terminal memory during checkout.
Weeks 3–8	During the holiday shopping season, the program quietly captures card numbers, expiration dates, and — at some terminals with an older configuration — the card verification code (CVV), each time a card is swiped or inserted.
Weeks 3–8	Every few hours, small batches of the captured data are sent out disguised as routine terminal “health-check” pings, timed to stay under the volume that would trigger UrbanTrail's basic network alerts.
Week 9	A fraud analytics team at a partner bank notices an unusually high rate of card-present fraud reports tracing back to recent purchases at UrbanTrail locations, and formally notifies UrbanTrail's security team.
Week 9–10	UrbanTrail engages a forensic investigator. The investigation finds the dormant contractor account (never disabled), the disguised firmware update, and confirms the POS network was never segmented from the rest of the corporate network as required by industry security standards.

Additional Facts

- Approximately 210,000 unique card numbers were affected across the 40 locations, with expiration dates and, for some transactions, CVV codes also captured.
- The former contractor was not involved in and had no knowledge of the attack — forensic logs confirm the activity originated from an external IP address, not from him.
- UrbanTrail Outfitters is privately held; it has no obligations tied to public company financial reporting.
- UrbanTrail does not handle any health information and has no operations in the European Union.

A NOTE FOR YOUR TEAM

It's tempting to call this an "insider threat" because a real employee's account was involved. Read the timeline closely — who actually took the actions that caused the breach?

Incident Response & Compliance Worksheet

Team members: _____

Part 1 — Cyber Kill Chain Mapping

For each of the seven Kill Chain stages, cite the specific evidence from your timeline that fits that stage. If your scenario doesn't clearly show a stage happening, say so and explain why (not every real incident has visible evidence at every stage).

Kill Chain Stage	Evidence from the Timeline
1. Reconnaissance	
2. Weaponization	
3. Delivery	
4. Exploitation	
5. Installation	
6. Command & Control (C2)	
7. Actions on Objectives	

Part 2 — MITRE ATT&CK TTP Table

Identify at least five key attacker actions from your timeline. For each one, name the Tactic (the goal), the Technique (the method), and, where the scenario gives you enough detail, the Procedure (the specific implementation). You do not need to know exact MITRE technique ID numbers — describe them in your own words, grounded in what the scenario tells you.

Attacker Action	Tactic (Why)	Technique (How)	Procedure (What Tool)

Optional stretch goal: if you have internet access, look up one of your techniques on attack.mitre.org and note its real technique ID (e.g., T1566 for Phishing).

Part 3 — Attack Type Classification

Which of the five common attack types from Lesson 16 (Malware, Phishing, Insider Threat, DoS/DDoS, or APT) best describes this incident? More than one may apply — identify the primary type and any secondary types, and justify each with evidence.

PRIMARY ATTACK TYPE

JUSTIFICATION (CITE SPECIFIC EVIDENCE)

SECONDARY ATTACK TYPE(S), IF ANY, AND WHY

WATCH FOR THE TRAP

Some details in your scenario are designed to make one classification look obvious at first glance. Before you finalize your answer, trace exactly who took each action and where it truly originated.

Part 4 — Regulatory & Compliance Impact Analysis

Consider all four frameworks from Lesson 15: HIPAA, GDPR, PCI-DSS, and SOX. For each one, state whether it applies to this incident and why — or why not.

Framework	Applies? (Y/N)	Why or Why Not — Cite Evidence
HIPAA		
GDPR		
PCI-DSS		
SOX		

IF A FRAMEWORK APPLIES: WHAT DOES IT REQUIRE NEXT?

Consider notification timelines, who must be notified, and any other concrete obligations covered in Lesson 15.

ESTIMATED STAKES

Using evidence-based figures from Lesson 15 (e.g., IBM's Cost of a Data Breach Report, GDPR enforcement data), estimate the potential financial and reputational exposure for this organization. Show your reasoning, not just a number.

Part 5 — Audit & Remediation Plan

Using the four-phase audit lifecycle from Lesson 15 (Planning → Execution → Reporting → Follow-Up), draft a plan for how this organization should audit and remediate the gaps that allowed this incident to happen.

Phase	Prompt	Your Plan
Planning	<i>What will you audit? Which systems, policies, or departments are in scope? Who needs to be involved?</i>	
Execution	<i>What evidence will you gather? What controls will you test?</i>	
Reporting	<i>What are the key findings? How would you rate their severity (low / medium / high)?</i>	
Follow-Up	<i>What specific remediation steps need to happen, and how will you verify they were completed?</i>	

Part 6 — Security Awareness & Culture Proposal

Design a targeted response that addresses the human and cultural root cause of this incident — not just the technical gap.

TRAINING FOCUS

Which Lesson 15 training topic(s) — phishing, password hygiene, data handling, or physical security — would have the biggest impact here, and for which audience (e.g., front-line staff, IT, executives)?

DELIVERY FORMAT & REINFORCEMENT

How should this training be delivered (in-person, online module, simulation), and how will you reinforce it over time so it isn't a one-time event?

ONE CULTURE INITIATIVE

Propose one specific culture-building step — e.g., a leadership action, a no-blame reporting change, or a way to track progress with metrics — tied to what actually went wrong in this scenario.

Part 7 — Executive Summary & Presentation Outline

Present a “board readout” summarizing this incident to a non-technical audience.

Segment	Your Notes
What happened	<i>The plain-language version — no jargon. What was accessed, how, and for how long?</i>
How it happened	<i>Walk the board through the Kill Chain stages and the key TTPs, in order.</i>
What it means for us	<i>Which regulations apply, what we're obligated to do, and by when.</i>
What we're doing about it	<i>Your audit & remediation plan and your awareness/culture proposal — the headline actions.</i>

Grading Rubric

Category	Points Possible
Kill Chain Mapping	15
MITRE ATT&CK TTP Table	15
Attack Type Classification	15

Regulatory & Compliance Analysis	20
Audit & Remediation Plan	15
Awareness & Culture Proposal	10
Presentation & Executive Summary	10
TOTAL	100 Scale (0-4) 0-24=0, 25-59=2, 60-74=3, 75 > = 4